

Github Audit Report

Control Description: Github organization settings require MFA to be enabled.

Conclusion: Fail

Test Procedures:

- 1 Internal Audit (IA) obtained and inspected the org-wide MFA settings.

Test Attributes:

- two_factor_requirement_enabled was set to true.

Control Description: Code repositories have branch protection rules enabled.

Conclusion: Fail

Test Procedures:

- 1 Internal Audit (IA) obtained and inspected a list of all repositories in the Github organization.
- 2 IA worked with the engineering team to determine which repositories were in-scope for the audit.
- 3 For each in-scope repository, IA gathered a the branch protection rules and rulesets.
- 4 IA inspected all in-scope rulesets testing checking for the test attributes below.

Test Attributes:

- An active ruleset OR branch protection rule is in enforced on the repository.
- Pull requests merging into the 'main' branch require at least one approval.

Sample Number	Repository Name	Conclusion	Comments
1	training	Fail	Branch protection exists but does not require PR approval
2	bp-bypass	Pass	
3	ruleset-bypass	Fail	Branch protection exists but does not require PR approval
4	ruleset-no-bypass	Fail	No branch protection rules or rulesets configured
5	bp-no-bypass	Pass	

Control Description: Code changes are approved by a separate user before they are deployed to production.

Conclusion: Fail

Test Procedures:

- 1 Internal Audit (IA) obtained and inspected a list of all repositories in the Github organization.
- 2 IA worked with the engineering team to determine which repositories were in-scope for the audit.
- 3 For each in-scope repository, IA gathered a list of merged pull requests (PR).
- 4 IA randomly sampled 5 PRs from each in-scope repo and tested for the attributes below.

Test Attributes:

- The PR was approved before it was merged to the main branch.
- The PR was opened and approved by separate users.

Sample Number	Repository Name	PR Number	Conclusion	Comments
1	training	1	Fail	No valid approvals before merge
2	training	2	Pass	
3	training	3	Pass	
4	training	4	Fail	No valid approvals before merge